

Narrativa explicativa – Paquete GQM + PRAGMATIC aplicado a indicadores OCTAVE nacionales

Texto base para explicar a decisores, CISOs y equipos de análisis por qué se ha adoptado el enfoque combinado GQM + PRAGMATIC, y cómo usarlo sin perderse en la selva de las métricas.

1. Por qué un marco GQM + PRAGMATIC

Durante años hemos acumulado indicadores de ciberseguridad como quien colecciona cromos: muchos, vistosos, difíciles de explicar y de dudosa utilidad para tomar decisiones. El resultado: cuadros de mando que impresionan a primera vista y confundEN a la segunda.

El paquete GQM + PRAGMATIC aplicado a los indicadores OCTAVE nacionales persigue un objetivo sencillo, aunque ambicioso: **que cada métrica pueda justificar su existencia.**

- GQM (Goal–Question–Metric) obliga a comenzar por los objetivos, seguir por las preguntas y llegar, solo al final, a las métricas.[web:79][web:82][web:88]
- PRAGMATIC nos ayuda a separar las métricas que iluminan de las que solo deslumbran, evaluando su calidad en nueve dimensiones: Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable.[web:83][web:86][web:89]

Aplicado a los indicadores OCTAVE propuestos para España (inventario de servicios esenciales, cobertura ENS, incidentes, vulnerabilidades, capacidad de respuesta, etc.), este enfoque permite construir un sistema de medición **trazable, defendible y útil** a escala nacional.

2. De los objetivos de país a las métricas técnicas

Los objetivos nacionales en ciberseguridad –reforzar la resiliencia de servicios esenciales, garantizar la protección de datos personales, cumplir ENS y NIS2, mejorar la confianza digital– son, por naturaleza, abstractos. Nadie puede medir directamente "la resiliencia del país"; lo que sí podemos medir son **manifestaciones concretas** de esa resiliencia.[web:84][web:90][web:87]

GQM nos fuerza a recorrer este camino:

1. Objetivos: por ejemplo, "Reducir la exposición de los servicios esenciales a vulnerabilidades críticas".
2. Preguntas: "¿Qué porcentaje de sistemas críticos tiene inventarios actualizados?", "¿Cuántos sistemas presentan vulnerabilidades críticas sin parchear en plazo?".
3. Métricas: "Porcentaje de servicios esenciales con inventario TIC actualizado", "Porcentaje de sistemas críticos con vulnerabilidades críticas abiertas más de X días".

Solo cuando existe este hilo argumental es posible responder con seriedad a la pregunta favorita de cualquier ministra, consejero o consejero delegado: **"¿Y este número qué me está diciendo exactamente?"**.

3. Evaluar las métricas con PRAGMATIC

No basta con que una métrica exista: debe ser buena. El enfoque PRAGMATIC propone evaluar cada métrica con nueve criterios que, más que un acrónimo, son una lista de preguntas incómodas para quien diseñó la métrica:[web:83][web:86][web:92]

- ¿Es Predictiva? ¿Me ayuda a anticipar problemas, o solo a rellenar informes retrospectivos?
- ¿Es Relevante para las decisiones de quienes la reciben, o es un capricho del área técnica?
- ¿Es Accionable? ¿Su variación sugiere acciones concretas?
- ¿Es Genuina? ¿Refleja la realidad o puede maquillarse con facilidad?
- ¿Es Significativa y comprensible para alguien sin doctorado en siglas?
- ¿Es Precisa y fiable para lo que se pretende?
- ¿Es Oportuna? ¿Llega a tiempo para corregir el rumbo?
- ¿Es razonablemente Independiente de sesgos e intereses?
- ¿Es Rentable? ¿El coste de medirla está justificado por el valor que aporta?

La "Matriz de Evaluación PRAGMATIC" puntúa cada métrica principal de los 15 indicadores OCTAVE nacionales según estos criterios, permitiendo **priorizar** cuáles merece la pena mantener, mejorar o jubilar.

4. Ejemplos ilustrativos

- El porcentaje de servicios esenciales con inventario TIC actualizado es altamente relevante y accionable: si el porcentaje es bajo, la acción es obvia; si mejora, el riesgo estructural disminuye.
- El número de interrupciones significativas de servicios esenciales debidas a ciberincidentes es profundamente significativo (lo entiende cualquiera) y muy predictivo del impacto social y político.
- Las pérdidas económicas agregadas estimadas son muy relevantes para el debate público y el ROI, pero tienden a ser menos precisas y más costosas de calcular; conviene manejarlas con cautela metodológica.[web:51][web:92]

Estos matices ayudan a evitar que las métricas se conviertan en fetiches: se usan sabiendo qué pueden decir y qué no.

5. Encaje con ENS, NIS2 y marcos internacionales

El paquete QQM + PRAGMATIC está diseñado para convivir con el ecosistema normativo y de buenas prácticas existente:

- ENS (RD 311/2022) exige gestión basada en riesgos, vigilancia continua y auditoría; varios indicadores (cobertura ENS, brechas de capacidad, alineamiento con ENS) se derivan directamente de estos requisitos.[web:60][web:63][web:71]
- NIS2 subraya la gestión de riesgos, la notificación de incidentes y la responsabilidad de la alta dirección; métricas como incidentes por sector, tiempo de respuesta y continuidad de servicios esenciales están alineadas con ello.[web:84][web:81][web:93]
- Los marcos de ENISA, OCDE, GCI, NCSI aportan referentes internacionales de madurez y capacidad; el sistema de indicadores OCTAVE nacionales puede mapearse a estos índices, facilitando comparaciones y diálogo europeo.[web:19][web:21][web:26][web:51]

Así, cuando se presenta un cuadro de mando nacional, no se está improvisando: se está hablando en un idioma compatible con las exigencias y métricas del entorno europeo e internacional.

6. Cómo utilizar este paquete en la práctica

4. Diseñar o revisar el catálogo de indicadores nacionales usando GQM, asegurando que cada métrica responde a un objetivo claro.
5. Aplicar la matriz PRAGMATIC para evaluar cada métrica actual o candidata;
6. Métricas con bajas puntuaciones globales → revisar, redefinir o eliminar.
7. Métricas fuertes en Predictiva/Relevante/Accionable → priorizar para el cuadro de mando.
8. Vincular las métricas a procesos de decisión concretos:
9. Inventarios y vulnerabilidades → priorización de inversiones técnicas y de supervisión.
10. Incidentes, tiempos de respuesta y continuidad → refuerzo de capacidades CSIRT, ejercicios conjuntos.
11. Pérdidas económicas y confianza digital → narrativa de ROI y de política pública.
12. Revisar periódicamente el catálogo y las puntuaciones PRAGMATIC, adaptándolo a nuevos requisitos normativos, amenazas emergentes y lecciones aprendidas.

7. Mensaje final

Medir ciberseguridad a nivel nacional es, inevitablemente, un ejercicio de aproximación: los datos son incompletos, las amenazas cambian y las organizaciones, a veces, responden con más entusiasmo en los cuestionarios que en la realidad.

Precisamente por eso es crucial contar con:

- Un método como GQM, que obliga a empezar por el "para qué" antes que por el "cuánto".
- Un filtro como PRAGMATIC, que nos impide encariñarnos con métricas inútiles aunque queden muy bien en la diapositiva.

Si a esto le sumamos marcos como OCTAVE, ENS y NIS2, lo que obtenemos no es un sistema perfecto, pero sí algo mucho mejor que una colección de números sueltos: un **lenguaje común para hablar de riesgos, capacidades y decisiones** en ciberseguridad nacional con la seriedad que merece... y con la ironía justa para seguir haciéndolo año tras año.